Network Intrusion Detection & Traffic Forensics Guide

Complete Technical Breakdown of Project 2 Attack Vectors, Suricata Signatures, Zeek Telemetry, Live Evidence & Infrastructure Hardening

STACK: SURICATA 8.0 NIDS • ZEEK 9.0 NSM • WIRESHARK FORENSICS • AF-PACKET • LINUX VIRTUAL BRIDGE

1. Architectural Context: OWASP Top 10 vs. Network Attacks

Before investigating packets, it is critical to clarify a common industry misconception regarding security frameworks—especially for technical interviews:

> **CRUCIAL FRAMEWORK DISTINCTION: OWASP TOP 10 VS. MITRE ATT&CK**
> There is no official "OWASP Top 10 for Network Attacks." The OWASP Top 10 (2021 and 2025 release) is strictly a **Web Application & API Security (OSI Layer 7)** framework. For low-level network intrusions, C2 beaconing, port scanning, and protocol tunneling (OSI Layers 3, 4, and 7 network transport), enterprise SOC teams use the **MITRE ATT&CK Framework**.
> However, network attacks analyzed in Project 2 directly exploit or trigger OWASP Top 10 Application categories when crossing the wire. Both mappings are detailed below for technical precision.

Attack Vector	OSI Layer	MITRE ATT&CK ID	Related OWASP 2025 Mapping	Suricata SID
1. Raw SYN Port Scans	Layer 4 (TCP)	`T1046` Network Discovery	A02:2025 Security Misconfiguration (Exposed services)	`1000001`
2. Base64 HTTP User-Agents	Layer 7 (HTTP)	`T1071.001` / `T1132.001`	A05:2025 Injection & A09:2025 Logging Failures	`1000002`
3. SSH Egress Tunnels	Layer 4/7 (SSH)	`T1572` Protocol Tunneling	A01:2025 Broken Access Control (Unfiltered Egress)	`1000003`
4. C2 Beaconing (Cobalt Strike)	Layer 7 (HTTP)	`T1071.001` / `T1041`	A08:2025 Integrity Failures & A09 Logging Failures	`1000004`
5. Rogue / Default TLS Certs	Layer 6/7 (TLS)	`T1587.003` Digital Certs	A04:2025 Cryptographic Failures (Untrusted Certs)	`1000005`
6. DNS Exfiltration Tunnels	Layer 7 (DNS)	`T1048.003` DNS Exfiltration	A02:2025 Security Misconfiguration (Open DNS Egress)	`1000006`

2. Deep-Dive Breakdown of Project 2 Attack Vectors & Live Evidence

Attack 1: Raw SYN Port Scanning (Stealth / Half-Open Recon)

MITRE: T1046 (Network Service Discovery) **OWASP: A02:2025 Security Misconfiguration** **Layer 4 (TCP)**

How It Works: In a half-open SYN scan (e.g., `nmap -sS`), the attacker rapidly transmits TCP SYN packets across port ranges without completing the 3-way handshake. When an open port responds with `SYN-ACK`, the scanner immediately transmits a `RST` frame to abort connection establishment. Closed ports respond with `RST-ACK`.

Suricata Signature:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"SOC-ALERT - Potential Nmap TCP SYN Port Scan Detected";
flags:S,12; flow:stateless; detection_filter:track by_src, count 20, seconds 5; classtype:attempted-recon;
sid:1000001; rev:1;)
```

- `flags:S,12;`: Matches pure SYN packets while masking out CWR (bit 1) and ECE (bit 2) RFC 3168 ECN congestion bits to eliminate false negatives.
- `flow:stateless;`: Evaluates raw datagrams without requiring TCP session state tables.

- `detection_filter:track by_src, count 20, seconds 5;`: Tracks state per source IP, suppressing alerts for the first 20 probes and triggering only on sustained bursts to eliminate false alarms from legitimate client traffic.

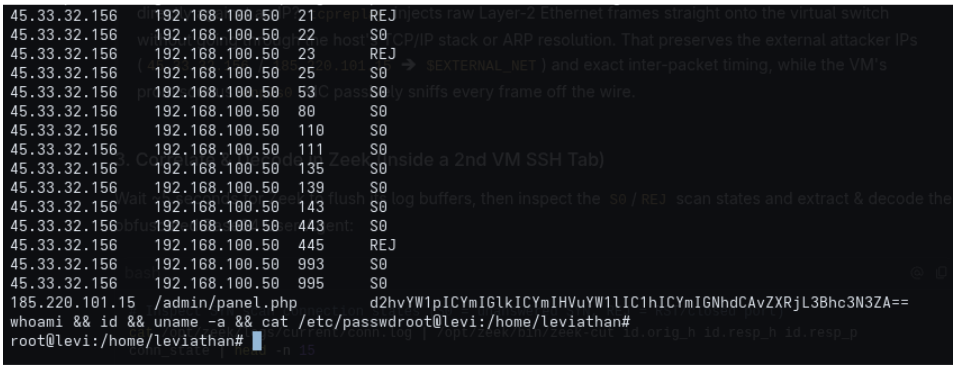


Figure 1: Live Zeek conn.log analysis displaying S0/REJ states alongside decoded Base64 command execution.

INFRASTRUCTURE DEFENSE & HARDENING

- **Stateful Firewall** / **Rate Limiting:** Deploy nftables rate-limiting rules (e.g. `ct state new limit rate 15/minute drop`) to throttle SYN probes at the perimeter.
- **Suricata IPS Inline Mode:** Switch Suricata from IDS (`alert`) to IPS (`drop`) using `--af-packet` inline IPS mode to actively drop packets from aggressive scanning sources.
- **Fail2ban** / **Port Knocking:** Dynamically ban IPs exhibiting multi-port connection drops within short windows.

Attack 2: Obfuscated Base64-Encoded HTTP User-Agents (C2 / Web Shell)

MITRE: T1071.001 (Web Protocols) / T1132.001 (Encoding) **OWASP: A05:2025 Injection / A09 Logging Failures** **Layer 7 (HTTP)**

How It Works: Attackers hide remote shell commands or C2 authentication tokens inside the HTTP `User-Agent` header. Because standard Web Application Firewalls (WAFs) often inspect URI parameters and POST bodies while overlooking request headers, Base64-encoded payloads bypass naive string filters.

Suricata Signature:

```
alert http $EXTERNAL_NET any -> $HOME_NET any (msg:"SOC-ALERT - Obfuscated Base64 String in HTTP User-Agent (Possible C2)"; flow:established,to_server; http.user_agent; pcre:"/^[A-Za-z0-9+\/]{30,}={0,2}$/"; classtype:trojan-activity; sid:1000002; rev:1;)
```

- `http.user_agent;`: Normalizes and isolates the User-Agent buffer from the HTTP stream.
- `pcre:"/^[A-Za-z0-9+\/]{30,}={0,2}$/";`: Enforces strict Base64 character alphabet validation with minimum length 30 and terminal padding. Valid browser strings containing tokens like `Mozilla/5.0` are ignored.
- **Forensic Extraction:** In Zeek's `http.log`, the User-Agent was extracted and decoded via `base64 -d`, uncovering the reconnaissance command: `whoami && id && uname -a && cat /etc/passwd`.

INFRASTRUCTURE DEFENSE & HARDENING

- **WAF Header Validation (ModSecurity / Coraza):** Enforce strict regular expressions rejecting non-RFC compliant User-Agents or unauthenticated strings lacking valid browser identifiers.
- **Zero-Trust Web Application Architecture:** Treat all HTTP headers as untrusted user input; sanitize and log headers before passing them to application runtime logic.

Attack 3: Unauthorized Outbound SSH Egress Tunnels (Reverse Port Forwarding)

MITRE: T1572 (Protocol Tunneling) / T1021.004 (SSH) **OWASP: A01:2025 Broken Access Control** **Layer 4/7 (SSH)**

How It Works: Internal compromised endpoints establish an outbound SSH connection (`ssh -R`) to an external attacker-controlled server over allowed egress ports (e.g., port 443). Once connected, the encrypted SSH tunnel allows the external attacker to route commands back into the internal network, completely evading perimeter inbound firewall rules.

Suricata Signature:

```
alert tcp $HOME_NET any -> $EXTERNAL_NET ![22] (msg:"SOC-ALERT - Suspicious Outbound SSH Tunnel on Non-Standard Port"; flow:established,to_server; content:"SSH-2.0-"; depth:8; classtype:bad-unknown; sid:1000003; rev:1;)
```

- `![22];`: Flags any outbound traffic targeted at destination ports other than standard SSH (port 22).
- `content:"SSH-2.0-"; depth:8;`: Validates RFC 4253 protocol compliance by scanning the first 8 bytes of the client handshake packet.
- `flow:established,to_server;`: Tracks outbound connection initiation moving from the internal client towards the external listener.

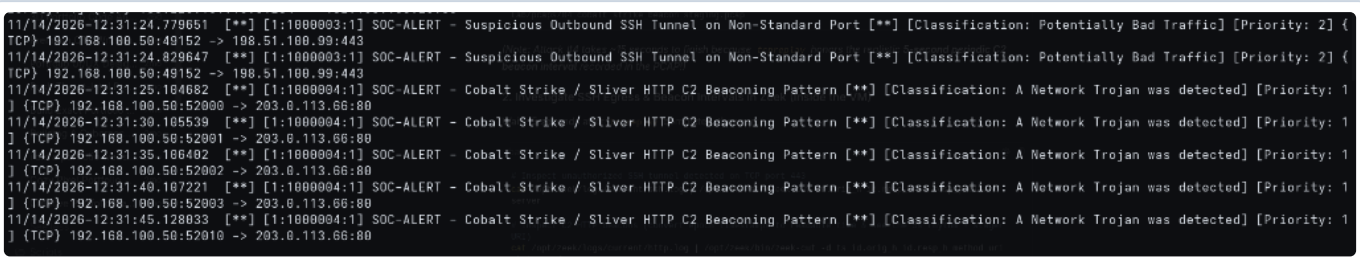


Figure 2: Suricata fast.log capturing Unauthorized SSH Egress on TCP/443 alongside periodic 5.0s C2 Heartbeats.

INFRASTRUCTURE DEFENSE & HARDENING

- **Strict Egress Filtering (Zero-Egress Policy):** Default-deny all outbound traffic at the edge firewall; only allow web traffic through an authenticated corporate Next-Gen Firewall (NGFW) or forward proxy.
- **Protocol Inspection (App-ID / Deep Packet Inspection):** Block connections on port 443 whose application layer does not match genuine TLS/HTTPS handshakes.
- **Host SSH Hardening:** Configure `/etc/ssh/sshd_config` with `GatewayPorts no` and `AllowTcpForwarding no` on servers to prevent unauthorized tunneling.

Attack 4: Command & Control (C2) Beaconing & Payload Staging (Cobalt Strike / Sliver)

MITRE: T1071.001 (Web Protocols) / T1041 (Exfiltration Over C2) **OWASP: A08:2025 Integrity Failures** **Layer 7 (HTTP)**

How It Works: Implants deployed inside an enterprise do not maintain persistent noisy connections. Instead, they transmit rhythmic heartbeat requests (beacons) at regular intervals (e.g., exactly every 5.0 seconds). Once tasked, the implant downloads a second-stage payload via malleable C2 URIs (such as 4-character checksum URIs like `/aB3z` or `/submit.php?id=`).

Suricata Signature:

```
alert http $HOME_NET any -> $EXTERNAL_NET any (msg:"SOC-ALERT - Cobalt Strike / Sliver HTTP C2 Beaconing
Pattern"; flow:established,to_server; http.method; content:"GET"; http.uri; pcre:"/^\/(submit\.php\?
id=[0-9a-fA-F]{8}|activity|[a-zA-Z0-9]{4})$/"; classtype:trojan-activity; sid:1000004; rev:1;)
```

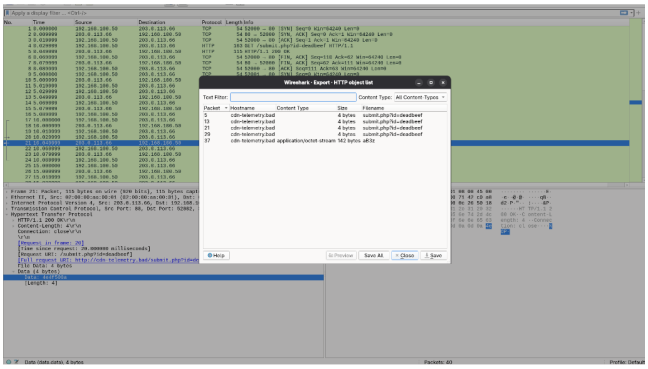


Figure 3: Wireshark Export HTTP Object window isolating periodic beacons and the 142-byte stager binary (aB3z).

```
leviathan@fedora:~$ file ~/Cybersecurity/Project-2-NIDS-Forensics-Lab/pcaps/aB3z
sha256sum ~/Cybersecurity/Project-2-NIDS-Forensics-Lab/pcaps/aB3z
strings ~/Cybersecurity/Project-2-NIDS-Forensics-Lab/pcaps/aB3z
/home/leviathan/Cybersecurity/Project-2-NIDS-Forensics-Lab/pcaps/aB3z: ELF 64-bit LSB *unknown arch 0x5f43* (SYSV)
1d830b572ebe373ac2625f8ecc42b68121e4b2e3893e142984c6b2ff23d5f769  /home/leviathan/Cybersecurity/Project-2-NIDS-Forensics-Lab/pcaps/aB3z
SOC_LAB_COBALT_STRIKE_SIMULATED_STAGER_PAYLOAD_DO_NOT_EXECUTE_
leviathan@fedora:~$
```

Figure 4: Non-destructive forensic triage of carved binary: SHA-256 hash calculation and string extraction.

INFRASTRUCTURE DEFENSE & HARDENING

- **EDR Behavioral Monitoring:** Deploy Endpoint Detection and Response (EDR) agents to detect memory injection, reflective DLL loading, and abnormal parent-child process spawns.
- **Proxy Jitter & Beacon Detection:** Configure automated analytics on proxy/Zeek logs to calculate inter-arrival connection variance; flag connections exhibiting rhythmic jitter < 10%.
- **DNS & IP Threat Intelligence Feeds:** Ingest known C2 framework infrastructure lists into perimeter DNS firewalls for automated blocking.

Attack 5: Rogue / Default Cobalt Strike TLS Certificate Impersonation

MITRE: T1587.003 (Digital Certificates) / T1573 (Encrypted Channel) **OWASP: A04:2025 Cryptographic Failures** **Layer 6/7 (TLS)**

How It Works: Attackers encrypt C2 communications with TLS/HTTPS to blind network monitors. However, the X.509 server certificate is exchanged in cleartext during TLS Handshake Type 11. Cobalt Strike default team server configurations ship with a hardcoded self-signed certificate bearing serial number `08:bb:00:ee` (decimal: `146473198`) and a spoofed Microsoft Corporation identity.

Suricata Signature:

```
alert tls $EXTERNAL_NET any -> $HOME_NET any (msg:"SOC-ALERT - Known Cobalt Strike Default TLS Certificate Serial Detected"; flow:established,to_client; tls.cert_serial; content:"08:bb:00:ee"; classtype:trojan-activity; sid:1000005; rev:1;)
```

- `tls.cert_serial;`: Sticky buffer extracting the normalized X.509 serial from unencrypted Handshake records.
- `flow:established,to_client;`: The external C2 server transmits its certificate to the internal client.

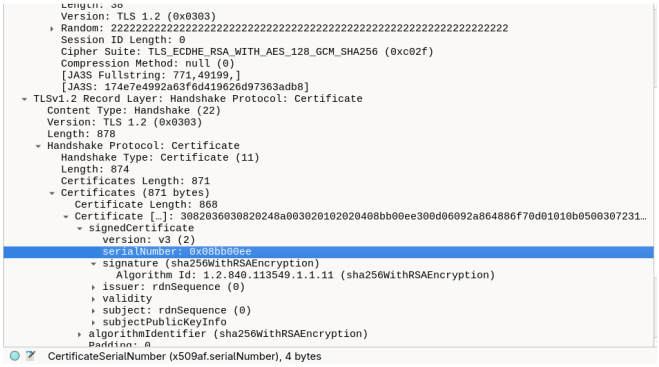


Figure 5: Wireshark dissection of TLS Handshake Type 11 confirming Serial Number 0x08bb00ee and JA3 fingerprint.

INFRASTRUCTURE DEFENSE & HARDENING

- **TLS Decryption / SSL Forward Proxy:** Implement enterprise TLS inspection to terminate and re-encrypt outbound HTTPS sessions, validating certificate trust chains and blocking self-signed certs.
- **Certificate Authority (CA) Whitelisting:** Reject outbound connections whose root CA is not in the enterprise-managed PKI trust store.
- **JA3 / JA4 Fingerprint Blocking:** Block TLS client/server combinations matching known adversary framework fingerprints at the edge firewall.

Attack 6: DNS Tunneling & Covert Data Exfiltration

MITRE: T1048.003 (Exfiltration Over DNS) **OWASP: A02:2025 Security Misconfiguration** **Layer 7 (DNS)**

How It Works: Attackers exploit open UDP/53 outbound access by registering an authoritative domain (e.g. `evil-dns-c2.com`). Malicious implants encode confidential files into hex or Base32 chunks and issue standard DNS lookups for subdomains exceeding 35 characters. The authoritative server receives and reassembles the chunks without any direct connection between victim and attacker.

Suricata Signature:

```
alert dns $HOME_NET any -> $EXTERNAL_NET any (msg:"SOC-ALERT - Potential DNS Data Exfiltration Tunnel (Long Encoded Subdomain)"; flow:to_server; dns.query; pcre:"/^[a-zA-Z0-9_-]{35,}\./"; classtype:bad-unknown; sid:1000006; rev:1;)
```



Figure 6: Zeek dns.log query extraction and hex-stream decoding uncovering stolen database passwords and API keys.

INFRASTRUCTURE DEFENSE & HARDENING

- **Internal DNS Resolver Restriction:** Block all outbound UDP/TCP port 53 traffic at the firewall except from authorized internal enterprise DNS resolvers (prevent direct external resolver queries).
- **DNS Response Policy Zones (RPZ) & Sinkholing:** Deploy Protective DNS (e.g., Cisco Umbrella, Quad9) to dynamically block high-entropy, freshly registered domains (NRDs).
- **Shannon Entropy Inspection:** Flag DNS query labels exhibiting high mathematical entropy and anomalous byte-length distributions.

3. Complete Forensic Investigation Pipeline (Cheat Sheet)

When investigating network alerts, follow this structured 4-phase incident response triage workflow:

Stage	Tool & Command	Operational Objective	Forensic Artifact Recorded
1. Ingestion	`sudo tcpreplay -i virbr1 sample.pcap`	Replay raw Layer-2 Ethernet frames across isolated sniffing bridge.	Traffic metrics, packet count, interface link status.
2. Alerting	`tail -f /var/log/suricata/fast.log`	Real-time signature matching and priority categorization.	Alert timestamp, SID, classification, attacker/victim IP:port.
3. Telemetry	`zeek-cut id.orig_h query < dns.log`	Stateful protocol metadata extraction and behavioral analysis.	Connection durations, TCP states (S0/REJ), cert serials.
4. Deep Forensics	`wireshark sample.pcap` / `sha256sum`	TCP stream reconstruction, payload carving, and malware triage.	SHA-256 hash, extracted strings, certificate X.509 details.